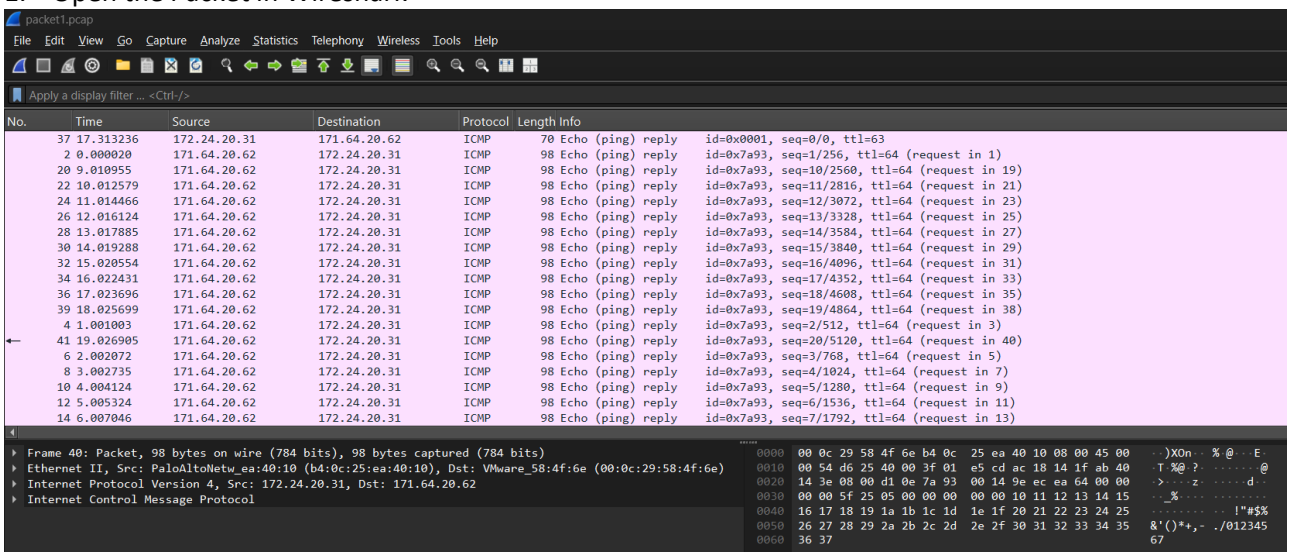
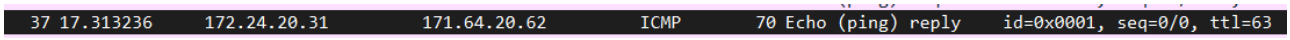
SUBJECT	VULNERABILITY ANALYSIS
CODE	IKB21004 & IKB21403
TASK	FILE ANALYSIS – SCANNING RESULT

Question 1: Analyse packet1.pcap and find the flag.

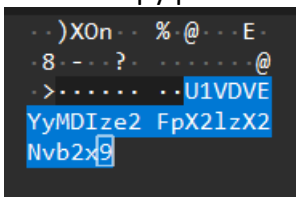
1. Open the Packet in Wireshark



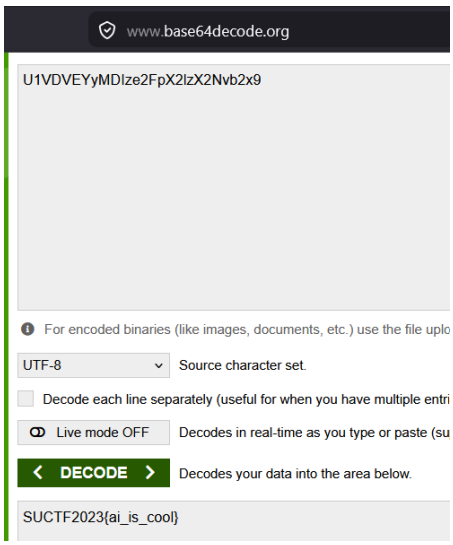
2. I've found an anomaly as this one is unique compared to the rest



3. I've copy paste this:



Then put it to base64decode.org:

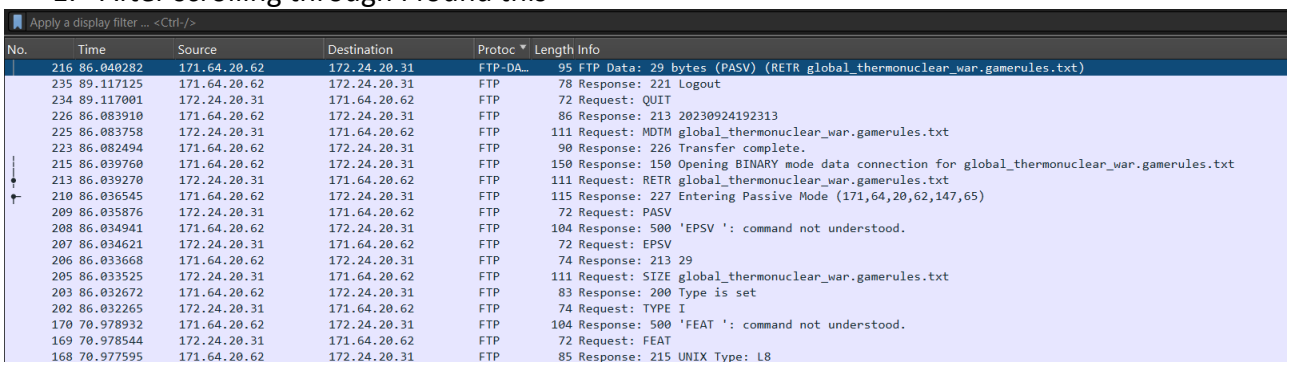


4. The flag:

SUCTF2023{ai_is_cool}

Question 2: Analyse packet2.pcap and find the flag.

1. After scrolling through I found this

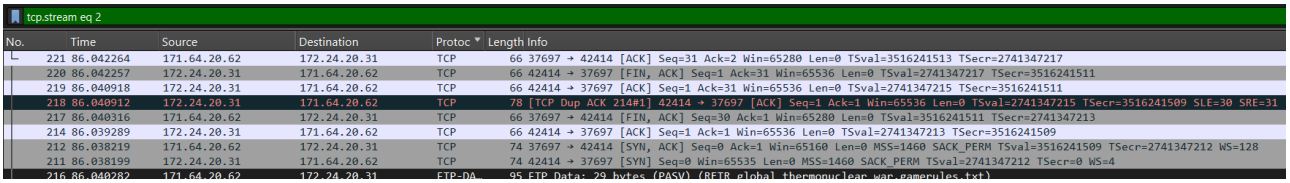


Apply a display filter ... <Ctrl-/>

No.	Time	Source	Destination	Protoc	Length	Info
216	86.040282	171.64.20.62	172.24.20.31	FTP-DA…	95	FTP Data: 29 bytes (PASV) (RETR global_thermonuclear_war.gamerules.txt)
235	89.117125	171.64.20.62	172.24.20.31	FTP	78	Response: 221 Logout
234	89.117001	172.24.20.31	171.64.20.62	FTP	72	Request: QUIT
226	86.083910	171.64.20.62	172.24.20.31	FTP	86	Response: 213 20230924192313
225	86.083758	172.24.20.31	171.64.20.62	FTP	111	Request: MDTM global_thermonuclear_war.gamerules.txt
223	86.082494	171.64.20.62	172.24.20.31	FTP	90	Response: 226 Transfer complete.
215	86.039760	171.64.20.62	172.24.20.31	FTP	150	Response: 150 Opening BINARY mode data connection for global_thermonuclear_war.gamerules.txt
213	86.039270	172.24.20.31	171.64.20.62	FTP	111	Request: RETR global_thermonuclear_war.gamerules.txt
210	86.036545	171.64.20.62	172.24.20.31	FTP	115	Response: 227 Entering Passive Mode (171,64,20,62,147,65)
209	86.035876	172.24.20.31	171.64.20.62	FTP	72	Request: PASV
208	86.034941	171.64.20.62	172.24.20.31	FTP	104	Response: 500 'EPSV ': command not understood.
207	86.034621	172.24.20.31	171.64.20.62	FTP	72	Request: EPSV
206	86.033668	171.64.20.62	172.24.20.31	FTP	74	Response: 213 29
205	86.033525	172.24.20.31	171.64.20.62	FTP	111	Request: SIZE global_thermonuclear_war.gamerules.txt
203	86.032672	171.64.20.62	172.24.20.31	FTP	83	Response: 200 Type is set
202	86.032265	172.24.20.31	171.64.20.62	FTP	74	Request: TYPE I
170	70.978932	171.64.20.62	172.24.20.31	FTP	104	Response: 500 'FEAT ': command not understood.
169	70.978544	172.24.20.31	171.64.20.62	FTP	72	Request: FEAT
168	70.977595	171.64.20.62	172.24.20.31	FTP	85	Response: 215 UNIX Type: L8

Those packets contain words.

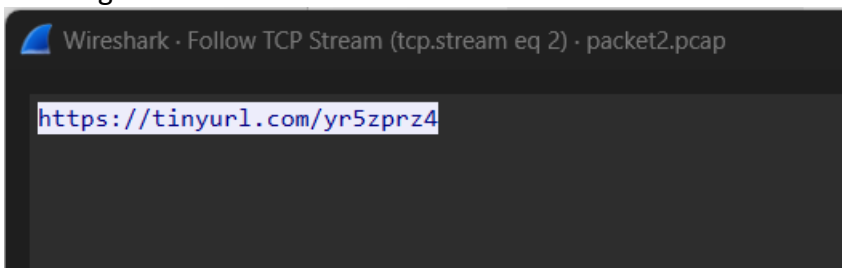
2. I realize those packets are scramble, so I try to combine them using TCP stream:



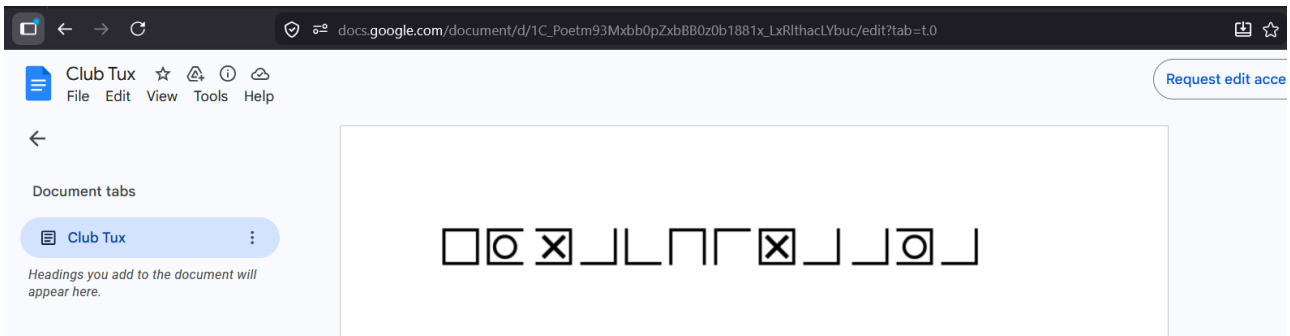
tcp.stream eq 2

No.	Time	Source	Destination	Protoc	Length	Info
221	86.042264	171.64.20.62	172.24.20.31	TCP	66	37697 → 42414 [ACK] Seq=31 Ack=2 Win=65280 Len=0 TSval=3516241513 TSecr=2741347217
220	86.042257	172.24.20.31	171.64.20.62	TCP	66	42414 → 37697 [FIN, ACK] Seq=1 Ack=31 Win=65536 Len=0 TSval=2741347217 TSecr=3516241511
219	86.040918	172.24.20.31	171.64.20.62	TCP	66	42414 → 37697 [ACK] Seq=1 Ack=31 Win=65536 Len=0 TSval=2741347215 TSecr=3516241511
218	86.040912	172.24.20.31	171.64.20.62	TCP	78	[TCP Dup ACK 214#1] 42414 → 37697 [ACK] Seq=1 Ack=1 Win=65536 Len=0 TSval=2741347215 TSecr=3516241509 SLE=30 SRE=31
217	86.040316	171.64.20.62	172.24.20.31	TCP	66	37697 → 42414 [FIN, ACK] Seq=30 Ack=1 Win=65280 Len=0 TSval=3516241511 TSecr=2741347213
214	86.039289	172.24.20.31	171.64.20.62	TCP	66	42414 → 37697 [ACK] Seq=1 Ack=1 Win=65536 Len=0 TSval=2741347213 TSecr=3516241509
212	86.038219	171.64.20.62	172.24.20.31	TCP	74	37697 → 42414 [SYN, ACK] Seq=0 Ack=1 Win=65160 Len=0 MSS=1460 SACK_PERM TSval=3516241509 TSecr=2741347212 WS=128
211	86.038199	172.24.20.31	171.64.20.62	TCP	74	42414 → 37697 [SYN] Seq=0 Win=65535 Len=0 MSS=1460 SACK_PERM TSval=2741347212 TSecr=0 WS=4
216	86.040282	171.64.20.62	172.24.20.31	FTP-DA…	95	FTP Data: 29 bytes (PASV) (RETR global_thermonuclear_war.gamerules.txt)

What I got is a URL:

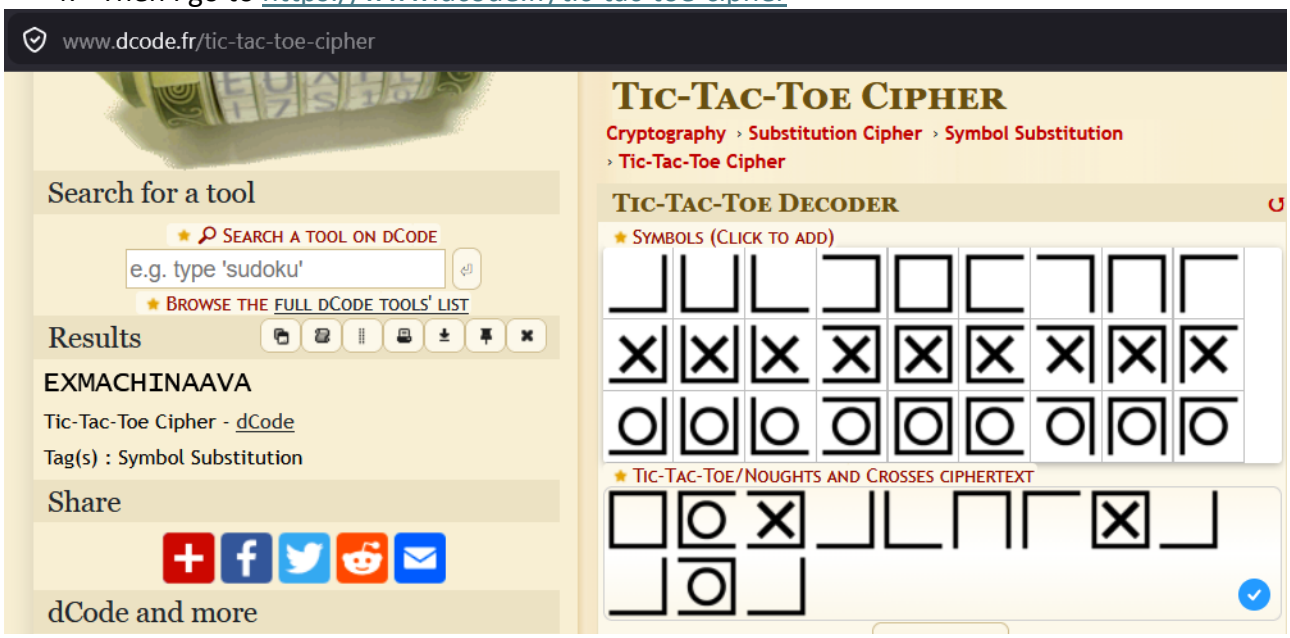


3. I copy paste the URL to my browser:



It led me to a google doc file and what seem to be a code.

4. Then I go to https://www.dcode.fr/tic-tac-toe-cipher



I insert the code from the google doc. Then decode it the result is EX MACHINA AVA

Flag: SUCTF2023{EX MACHINA AVA}

Question 3: Interpret an Nmap Output

PORT STATE SERVICE VERSION
21/tcp open ftp vs6pd 2.3.4
22/tcp open ssh OpenSSH 5.3p1
80/tcp open http Apache 2.2.8
139/tcp open netbios-ssn
445/tcp open microso6-ds Windows 7 Professional 7601 Service Pack 1

Questions:

1. What can an attacker do with each port?

21/tcp	FTP	Anonymous login, upload/download files, or exploit the known backdoor to get to root
22/tcp	SSH	Brute-force credentials, exploit version-specific vulnerabilities. Example user enumeration, denial of service. Or use stolen keys for remote access.

80/tcp	HTTP	Web application attacks, or access sensitive files.
139/tcp	NetBios	Enumerate shares, users, and workgroups
445/tcp	SMB	Access file shares, exploit SMBv1 vulnerabilities, or perform pass-the-hash attacks.

2. What vulnerabilities are likely present based on the version?

- **vsftpd 2.3.4** – Backdoor sending a username triggers a backdoor on port 6200, giving a root shell.
- **OpenSSH 5.3p1** – Weak ciphers off-by-one error in sshd, user enumeration. No trivial remote RCE, butpost-authentication risks.
- **Apache 2.2.8** – Multiple vulnerabilities: Range header DoS, HTTP request smuggling, and if PHP/mod_cgi is present, RCE is possible.
- **Windows 7 SP1 (SMB)** – Highly vulnerable to **EternalBlue** (MS17-010) – unauthenticated remote code execution on SMBv1. Also SMBv1 DoS, information disclosure, and potential for wormable attacks.

3. Which one is the highest risk and why?

- **Port 445 (SMB) on Windows 7 SP1:** Microsoft no longer releases new security patches unless under a paid ESU plan. Meaning it extremely exploitable.

4. What attack path can be built from this?

- **Reconnaissance –** Use **nmap** scripts to confirm EternalBlue vulnerability.
- **Initial compromise** – Exploit EternalBlue via Metasploit
- **Post-exploitation** – Dump hashes, install backdoors, enable RDP, or pivot to internal networks.

5. What should be the remediation?

- **Vsftpd:** Upgrade to the latest version.
- **SSH:** Update to OpenSSH latest version. Disable weak algorithms, use key-based auth.
- **Apache:** Update to OpenSSH 8.x (latest). Disable weak algorithms, use key-based auth, implement fail2ban.
- **General:** Run regular vulnerability scans, enforce least privilege, and maintain a patch management policy.

Question 4: Identify the OS (OS Fingerprinting) - TTL

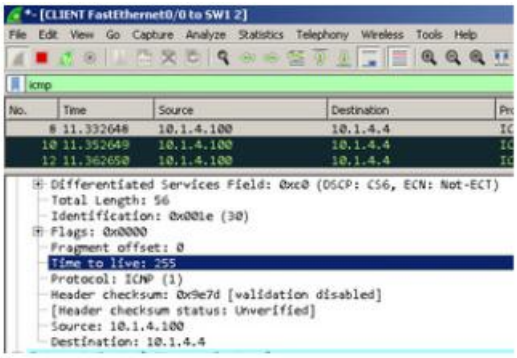
Image 1

```
[sk@ostechnix ~]$ ping -c5 localhost
PING localhost(localhost (::1)) 56 data bytes
64 bytes from localhost (::1): icmp_seq=1 ttl=64 time=0.063 ms
64 bytes from localhost (::1): icmp_seq=2 ttl=64 time=0.057 ms
64 bytes from localhost (::1): icmp_seq=3 ttl=64 time=0.070 ms
64 bytes from localhost (::1): icmp_seq=4 ttl=64 time=0.067 ms
64 bytes from localhost (::1): icmp_seq=5 ttl=64 time=0.056 ms

--- localhost ping statistics ---
5 packets transmitted, 5 received, 0% packet loss, time 4096ms
rtt min/avg/max/mdev = 0.056/0.062/0.070/0.005 ms
```

Answer: Linux

Image 2



Answer: Cisco Router

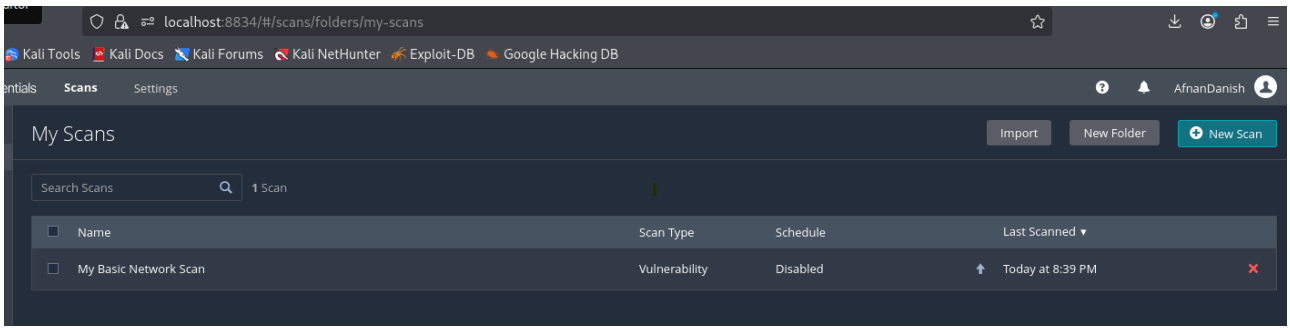
Image 3

```
64 bytes from 192.168.122.239: icmp_seq=1 ttl=128 time=6.85 ms
64 bytes from 192.168.122.239: icmp_seq=2 ttl=128 time=0.510 ms
64 bytes from 192.168.122.239: icmp_seq=3 ttl=128 time=0.601 ms
64 bytes from 192.168.122.239: icmp_seq=4 ttl=128 time=0.541 ms
64 bytes from 192.168.122.239: icmp_seq=5 ttl=128 time=0.558 ms
```

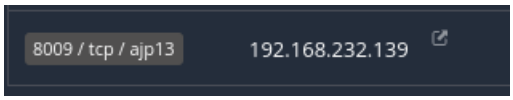
Answer: Windows

Question 5: Analyse the Nessus file

Upload to your nessus (Network_Scan.nessus) and analyse the files. Focus on critical or high findings that was identifies in analysis named “Ghostcat”.



1. What is the affected Port number



Answer: Port 9009

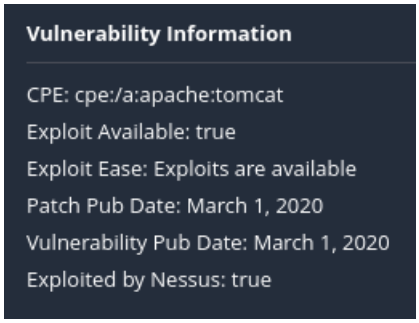
2. What is the Affected protocol

Answer: The affected protocol is **AJP (Apache JServ Protocol)**, specifically version 13 (ajp13). AJP is a binary protocol used for communication between Tomcat and web servers.

3. What is the CVSS Score of vulnerability found

Answer: This score indicates a critical severity level, nearing the maximum possible.

4. Can you find any exploit related to this vulnerability?



- Answer: **AV:N (Attack Vector: Network):** This vulnerability can be exploited remotely.
- **AC:L (Attack Complexity: Low):** The attack complexity is low, meaning that the attacker can reliably exploit the vulnerability with little to no additional information.
- **PR:N (Privileges Required: None):** The attacker does

not require any special privileges to exploit the vulnerability.

5. Find CVE for this vulnerability.

Reference Information

CVE: CVE-2020-1938, CVE-2020-1745